

Risk Assessment and Management Plan

This section conforms to the ISO/IEC 27005 standard, which provides guidelines for identifying and managing cybersecurity risks within an organisation. ISO/IEC 27005 has been selected as opposed to ISO/IEC 27001, because the broader governance of information security is not the primary focus of this document; instead, ISO/IEC 27005 provides a comprehensive framework for identifying, analysing, evaluating, and treating information security risks, focussing on risk management as a core component. This methodology is designed to complement the requirements of ISO/IEC 27001.

Assumptions

1. The system will provide global navigation services to commercial, government, and military clients.
2. The York Satellite Navigation Company is in good standing and relations with its competitors Global Positioning System (GPS) and the Global Navigation Satellite System (GNSS).
3. The system relies on encrypted communication between satellites, ground control stations, and user devices.
4. The satellite system requires continuous software and firmware updates to maintain operational security and performance.

1. Context Establishment

In this phase, we define the scope, identify relevant stakeholders, and evaluate the internal and external context to understand how the satellite system operates and where risks might arise, as per clause 6 of ISO/IEC 27005 [1]. This context will guide the risk identification and treatment process.

Information Assets

- Navigation data
- Command and control data for satellites
- Sensitive user location data

Critical Functions

- Secure delivery of positioning, navigation, and timing data
- Secure operation of satellites and ground stations
- Secure communication channels between satellites and ground stations

Business Objectives

- Provide continuous, accurate, and secure navigation services to users.
- Ensure the integrity, availability, and confidentiality of the navigation system, particularly for high-stakes applications such as military operations and autonomous vehicles.

Stakeholders

- Commercial Clients – Rely on the navigation system for logistics, transportation, and autonomous vehicle operations.

- **Government Clients** – Use the system for public infrastructure management and national security purposes.
- **Military Users** – Depend on the system for secure and precise navigation in mission-critical situations.
- **Suppliers** – Provide critical components such as satellite hardware, firmware, and maintenance services.
- **Regulatory Bodies** – Define standards for the security and reliability of satellite communications.

External and Internal Context

- **External** – Global cybersecurity threat landscape, regulations governing satellite operations, geopolitical factors.
- **Internal** – Organisational structure, resources, operational requirements, and supply chain dependencies.

2. Risk Identification

This phase identifies the information security risks that could impact the satellite system. As outlined by clause 7.2 of ISO/IEC 27005 [1], risks are identified by considering possible threats, vulnerabilities, and the assets that could be affected.

To identify the risks associated with York Satellite Navigation Company's operations, it is essential to identify the threats. ISO 27005 [1] defines a 'threat' as "a potential cause of an information security incident that could result in damage to a system or harm to an organisation". In this document, the risk assessment focuses on

evaluating the likelihood that York Satellite Navigation Company will be exposed to these threats.

The CCSDS Report Concerning Security Threats Against Missions [2] identifies four key sources of threats – Adversarial Sources, such as criminals, terrorists, national intelligence services, political activists, computer hackers and commercial competitors; Insider Sources, such as dishonest personnel, the inadvertent or disgruntled actions of staff members or business partners; Environmental Sources, such as solar flares, space debris or power outage; and Structural Sources, namely software or hardware failure.

In terms of vulnerabilities affecting systems on the ground, weak encryption on communication links presents a risk, as insufficient encryption would allow attackers to intercept or manipulate data. Additionally, the lack of stringent security controls within the supply chain could result in compromised hardware or software being integrated into the satellite system. Another significant vulnerability lies in software security; unpatched or inadequately secured satellite control software may be exploited by attackers to take over satellite operations. Furthermore, inadequate access control measures at ground control stations may enable unauthorised personnel to access critical systems, increasing the risk of operational compromise.

A loss of navigation capabilities could lead to significant service disruptions, particularly for critical infrastructure sectors like transportation, logistics, and defence. Unauthorised access to sensitive navigation data poses a risk of data breaches, which could lead to privacy violations and legal consequences.

Additionally, service outages or inaccurate navigation data could result in financial losses for clients relying on the system for precision and reliability. Lastly, the reputation of the organisation could be severely damaged if the satellite system is compromised, leading to a loss of trust among stakeholders.

3. Risk Assessment

In this phase, we perform risk analysis and evaluation to assess the risk assessment criteria of each identified risk. This follows the methodology in clause 7.3 of ISO/IEC 27005 [1], ensuring that risks are prioritised based on their potential impact on system security and operations.

Each identified risk is analysed in terms of its likelihood and impact. The likelihood is rated as low, medium, or high based on the potential for threats to exploit identified vulnerabilities. The impact is assessed based on the potential harm to the satellite system's operations and stakeholders and is rated as low, medium, or high depending on the severity of damage that the exploitation of a vulnerability would cause.

Threat	Likelihood	Impact	Risk Level
Interception of Data	Medium	High	High
Spoofing and Jamming	High	Medium	High
Commercial Competition	High	Low	Medium
Insider Threat	Low	Medium	Medium
Unauthorised Access	Low	High	Medium

Solar Flares	Low	High	Medium
Space Debris	Medium	High	High
Power Outage	Low	Medium	Medium
Hardware Failure	Medium	High	High
Software Failure	Medium	Medium	Medium
New Regulatory Requirements	Medium	Medium	Medium

High and medium risks should be prioritised for immediate treatment, while low risks may be tolerated or monitored depending on the organisation's overall risk tolerance strategy.

4. Risk Treatment

The risk treatment phase aims to manage and mitigate the risks that have been identified and assessed. Each risk is assigned an appropriate treatment strategy, and controls are implemented to reduce the likelihood of the risk occurring or its potential impact. As per clause 8 of ISO/IEC 27005, the risk treatment process ensures that risks are either mitigated, avoided, transferred, or accepted based on their severity and impact on the system.

Risk Treatment Strategies

1. Risk modification – Apply controls to reduce the likelihood or impact of a risk.
2. Risk avoidance – Modify or discontinue actions to eliminate the risk entirely.
3. Risk sharing – Splitting responsibilities and risk with a third party.

4. Risk retention – Acknowledge the risk without applying additional controls if the risk is within acceptable limits.

Risk	Treatment	Strategy
Interception of Data	Modify	Implement strong encryption and multi-factor authentication for satellite control systems to prevent unauthorised access.
Spoofing and Jamming	Modify	Use frequency-hopping spread-spectrum and signal monitoring techniques to reduce vulnerability to spoofing; use multiple uplink paths. [2]
Commercial Competition	Share	Maintain good relationships with GPS and GNSS and invest in new technologies to share the competitive risk, or purchase insurance to offset losses due to market competition.
Insider Threat	Modify	Apply role-based access control and conduct background checks and monitoring of staff and contractors to prevent malicious insider actions.
Unauthorised Access	Modify	Implement secure firewalls, IDS/IPS, and physical security. Implement stringent authorisation for staff such as 2FA and use levels of security access to limit the damage of a compromised account.
Solar Flares	Modify	Install radiation shielding on satellites and establish backup systems to ensure continued operation during solar events.

Space Debris	Modify	Implement collision detection and avoidance systems to reduce the likelihood of damage from space debris.
Power Outage	Modify	Install uninterruptible power supplies and redundant power systems at ground control stations to ensure continuous operation during outages.
Hardware Failure	Modify	Implement hardware redundancy and regular maintenance schedules to reduce the likelihood of system failure.
Software Failure	Modify	Conduct regular software updates, security patches, and testing to mitigate the risk of vulnerabilities being exploited.
New Regulatory Requirements	Accept	Regulatory requirements are beyond the organisation's control; focus on compliance as they arise.

Even after treatment, some residual risks may remain. The residual risk is evaluated to determine whether it falls within the organisation's risk tolerance. If not, additional treatment strategies may need to be implemented.

5. Risk Monitoring and Review

Risk management is a dynamic and continuous process. The monitoring and review phase ensures that the risk management framework remains effective over time,

particularly as new threats emerge, or system changes occur. This phase is consistent with clause 10.5 of ISO/IEC 27005. [1], which focuses on the continuous monitoring, review, and improvement of the risk management framework.

- Continuous Monitoring – Implement continuous monitoring of satellite systems and ground control stations, including real-time tracking of satellite telemetry, network traffic, and system logs to detect anomalies or potential security incidents.
- Incident Reporting and Response – Establish an incident reporting mechanism to quickly address any security breaches or disruptions. This includes defining clear roles and responsibilities for incident response teams.
- Regular Audits and Reviews – Conduct regular security audits of the satellite system, with a focus on evaluating the effectiveness of implemented controls and identifying any new risks that may have emerged.
- Threat Intelligence Updates – Maintain awareness of new threats through threat intelligence feeds and industry reports. This allows the organisation to update its risk assessment and treatment strategies in response to emerging risks.

Review and Improvement

- Periodic Risk Re-assessment – Conduct periodic risk assessments to evaluate the impact of any changes to the system (e.g., system upgrades, software updates, new regulations, or emerging threats).
- Control Effectiveness Review – Regularly assess the effectiveness of security controls to ensure that they continue to mitigate risks appropriately.

Adjustments should be made as necessary to maintain the security of the satellite system.

- Lessons Learned from Incidents – After any security incident or breach, conduct a post-incident review to identify any weaknesses in the system or gaps in the risk management process. These lessons should be incorporated into the risk management framework to prevent future incidents.

This risk assessment and management plan, based on ISO/IEC 27005, provides a structured approach to managing the cybersecurity risks associated with the York Satellite Navigation Company's LEO navigation satellite system. By following the risk management process outlined in ISO/IEC 27005, the organisation can effectively identify, assess, treat, and monitor risks to its satellite operations. The plan ensures that the satellite system is protected from a range of adversarial, insider, environmental, and structural threats, while also establishing a continuous monitoring and review process to adapt to evolving risks.

Threat Analysis

Two risks identified to York Satellite Navigation Company's operations are unauthorised access and insider sources. Both pose potentially serious issues to the security and reliability of the system and, if not properly managed, could lead to service disruptions, data breaches, or compromised satellite operations.

Unauthorised access can occur when attackers exploit vulnerabilities in access controls, credentials, or security protocols to gain access to our satellite control systems, communication systems or ground stations. This could result in unauthorised users gaining control of satellites, altering navigation data, causing service interruptions, or sharing the data they accessed to adversarial sources. Given the sensitive nature of the data being transmitted by the satellite system and its importance to government, military, and commercial clients, it is vital that access is only achieved by approved personnel.

To resolve this issue, the company should first implement multi-factor authentication for all users accessing critical systems. MFA adds an additional layer of security beyond just passwords by requiring multiple forms of verification, such as a password and a biometric scan or security token. This reduces the risk of compromised credentials leading to unauthorised access. Additionally, role-based access control should be employed, ensuring that employees or contractors only have access to the systems and data necessary for their roles. This limits the scope of potential damage should an unauthorised user gain access to an account. Finally, the company should ensure that it has a robust system for real-time monitoring and logging of all access attempts. By utilising intrusion detection systems and intrusion prevention systems, the company can identify suspicious access patterns and block malicious attempts before they lead to a security breach.

The second major threat, insider sources, refers to the risk posed by individuals within the organisation, such as employees, contractors, or trusted partners, who intentionally or unintentionally compromise security. Insider threats are particularly

difficult to detect because insiders already have legitimate access to systems and data. Malicious insiders may exploit their position to steal sensitive data, disrupt satellite operations, or provide external adversaries with access to critical infrastructure. In some cases, insiders may unintentionally become a threat through ignorance, such as a misunderstanding of the use or importance of security systems, or through mistakes, such as falling for phishing attacks or misconfiguring security settings.

To mitigate insider threats, YSNC should adopt several measures. Enhanced background checks and vetting procedures should be applied to employees and contractors, particularly those with access to sensitive systems. This will help reduce the risk of hiring individuals who may later act maliciously. Behaviour monitoring tools should be used to detect unusual activities within the system, such as accessing data outside normal work hours or attempting to escalate privileges. By using user and entity behaviour analytics, the system can flag abnormal behaviour and alert the security team before a potential incident escalates. Additionally, separation of duties should be implemented to ensure that no single employee has full control over critical operations, reducing the risk of an insider being able to conduct malicious activities without oversight.

The Risk Management Governance published by CYBOK [3] highlights that risk cannot be mitigated with technology alone, and that “educating people within an organisation is vital to ensuring cultural adoption of the principles defined in the risk management plan and associated security governance policy”. Regular security awareness training should be considered crucial in educating employees about risk

awareness and identifying potential threats such as phishing, social engineering, and other risks that could lead to unintentional security breaches.

In conclusion, unauthorised access and insider threats are two critical risks that could severely impact York Satellite Navigation Company's LEO navigation system. Implementing multi-factor authentication, role-based access control, real-time monitoring, enhanced background checks, and behavioural analytics will help mitigate these risks. Taking these steps ensures that the satellite system remains secure from both external and internal threats, maintaining the integrity and reliability of the service for the company's clients and stakeholders.

Legal, Ethical and Technical Issues

In operating the York Satellite Navigation Company's LEO navigation system, there are several key legal, ethical, and technical issues that require attention. Addressing these issues is essential not only for the protection of the system but also for maintaining compliance with regulations, upholding ethical standards, and securing long-term business success.

A major legal concern is compliance with data privacy regulations such as the General Data Protection Regulation (GDPR) and similar laws worldwide. The system processes sensitive navigation data, including personal and location information, which must be handled in line with these regulations. KPMG [4] states that digital trust is the key cybersecurity consideration for 2023, and compliance will underline YSNC's global commitment and obligation to resilient, trustworthy security.

Given an increase in cyber threats to essential services like energy, transportation, and healthcare, where the misuse of location data can have serious implications, there is growing regulatory scrutiny of location data, especially in critical infrastructure sectors. Failure to comply could result in substantial fines and damage to the company's reputation. Implementing strong data protection policies – such as ensuring user consent, data anonymisation, and secure data storage – will help the company avoid legal challenges and maintain the trust of clients, especially in sectors like defence and government, where data sovereignty is a key concern.

In addition to privacy regulations, the company must comply with international space laws and frameworks governing satellite operations. This includes obtaining licenses, adhering to frequency allocations, and following safety protocols for space debris management. As Low Earth Orbit becomes more crowded, space agencies are tightening regulations to manage traffic and prevent collisions. Non-compliance could result in sanctions, loss of operating licenses, or liability if satellite incidents occur. Keeping up with these regulations is essential to ensure that York Satellite Navigation Company remains a compliant and responsible operator.

From an ethical standpoint, the dual-use nature of satellite technology raises concerns. The same technology used for civilian applications, like navigation for transportation, also plays a crucial role in military operations, potentially including warfare or surveillance. Ethical questions about the use of dual-purpose technologies are growing, especially as emerging technologies, such as AI, are integrated into military systems. While working with government and military clients

is a necessary part of the business, the company should take a strong ethical stance on how its technology is used, ensuring it maintains a positive public image and avoids controversy.

On the technical side, post-quantum cryptography (PQC) is becoming increasingly important. Quantum computing poses a potential threat to traditional encryption methods, such as RSA and AES, which could be rendered vulnerable to quantum attacks. Recent research emphasises the need for organisations handling sensitive data to adopt PQC to future-proof their encryption and ensure continued security. For York Satellite Navigation Company, adopting PQC will protect its critical communication channels from future quantum threats and ensure that sensitive data remains secure.

By considering these legal, ethical, and technical issues, York Satellite Navigation Company can secure its LEO navigation system against emerging threats and ensure compliance with international regulations. Addressing these areas will strengthen the system's reliability and position the company as a leader in responsible, secure satellite operations.

References

- [1] BS EN ISO/IEC 27005:2024, *Information security, cybersecurity and privacy protection — Guidance on managing information security risks*. BSI, 2024 [viewed 16 October 2024]. Accessed online: <https://bsol-bsigroup-com.libproxy.york.ac.uk/Bibliographic/BibliographicInfoData/000000000030490478>
- [2] CCSDS, *Security Threats Against Space Missions*, CCSDS, 2022 [viewed 18 October 2024]. Accessed online: <https://public.ccsds.org/Pubs/350x1q3.pdf>
- [3] Burnap, Pete, *Risk Management & Governance Knowledge Area*, v1.1.1, CYBOK, 2021 [viewed 18 October 2024]. Accessed online: https://www.cybok.org/media/downloads/Risk_Management_Governance_v1.1.1.pdf
- [4] KPMG, *Cybersecurity considerations 2023*, KPMG, 2023 [viewed 20 October 2024]. Accessed online: <https://kpmg.com/us/en/articles/2023/cybersecurity-considerations.html>